Cuadro: qué se muestra en cada informe por nivel de prueba

Informes: TPRA/HTML (principal), PP, GC, BC, S3, B1, B2, B3. **Niveles**: N1 pasivo · N2 semi-activo · N3 activo · N4 invasivo.

0. Datos disponibles por nivel (base común a los 8 informes)

Fuente: gates por `test_level` en `_scan_provider` (asm_scan.py).

- **N1 pasivo**: DNS apex completo (IPv4/MX/NS/SPF/DMARC/DKIM/DNSSEC/CAA/MTA-STS/TLS-RPT/BIMI), subdominios CT (crt.sh), URLhaus/DNSBL, leaks, typosquatting, Social OSINT, OSINT externo (WHOIS/DNSDumpster/Shodan/Censys/theHarvester/InternetDB/Exposure), KUMO N1, Prism N1, Claude-OSINT N1.
- **N2 semi-activo**: + puertos 80/443, TLS/certificado, HTTPS (status/cabeceras/redirección), rutas públicas, vulns OSV, patching cadence, supply chain, CSP findings, cookies, WAF/cloud, KUMO N2 (favicon/robots), Prism N2 (website_analyzer), Claude-OSINT N2 (SSO/OIDC, secret scan), **Strix quick**.
- **N3 activo**: + subdominios por fuerza bruta, subdomain takeover, port-scan completo, FinalRecon, discovery API, **Strix standard**.
- **N4 invasivo**: + IP pivot, banner grab, CVE lookup, **Strix deep**.

> Los bloques se renderizan **solo si hay dato** (status=="ok"). Strix aparece de N2 en adelante y se oculta en N1 por diseño. generate_asm_passive_active_report.py queda excluido de la homologación pasivo/semi.

1. Cuadro: qué se muestra en cada informe por nivel de prueba

> **Nota de homologación**: el set de items es **idéntico en los 8 informes** — en N1 y N2 muestran exactamente los items listados abajo; solo cambia la forma de presentarlos (bloque <h4>, fila fc-row, span o hallazgo resumen). Lo que varía entre informes es el **contexto extra** (OWASP, scorecards, Strix).

Informe	Pasivo (N1) — mismo set en los 8	Semi-activo (N2) — mismo set en los 8, adicional al pasivo	Activo (N3)	Invasivo (N4)
TPRA / HTML (socradar, principal)	DNS: IPv4/IPv6, MX, NS, SPF, DMARC, DKIM, DNSSEC, CAA, MTA-STS, TLS-RPT, BIMI · Subdominios CT · Credenciales (leaks) · Typosquatting · DNSBL/URLhaus · OSINT: WHOIS, DNSDumpster, Shodan, Censys, theHarvester, Shodan InternetDB, Shodan Exposure · KUMO N1: Wayback, Breach Intel, Email Harvest · Prism N1: Breach Lookup, Onion/Dark Web, GitHub Recon, Gravatar · Claude-OSINT	Al set pasivo se añade: puerto 443 abierto, TLS versión, certificado, SAN · HTTP status code, server fingerprint, redirección · cabeceras HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy · rutas públicas · WAF/CDN · cloud storage · patching cadence, supply chain, CSP findings, cookies · KUMO N2: robots/Security.txt, favicon hash · Prism N2: Website Analyzer ·	+ subdominios por fuerza bruta, subdomain takeover, port-scan completo (tabla de puertos), FinalRecon, discovery API, Strix *standard* (tabla hallazgos severidad/CVE/CWE/CVSS + costo LLM)	+ banner grab, CVE lookup (vulndb/EPSS/KEV), IP pivot, Strix *deep*, severidades críticas

Informe	Pasivo (N1) — mismo set en los 8	Semi-activo (N2) — mismo set en los 8, adicional al pasivo	Activo (N3)	Invasivo (N4)
	N1: M365, SPF/DMARC, Org Attribution, CTI Chatter, Passive DNS, Cloud-native, HackerOne · Redes sociales. Presentación: bloques <h4> + contexto OWASP.	Claude-OSINT N2: SSO/OIDC probe, Secret Scan · Strix *quick*. Presentación: bloques <h4>.		
PP (ppasivo, azul sombreado)	Mismo set pasivo de la fila TPRA (DNS apex, CT, leaks, typos, DNSBL/URLhaus, OSINT externo, KUMO/Prism/CO N1, redes). Presentación: filas `fc-row` prefijo "Pasivo ·".	Mismo set semi-activo de la fila TPRA (servicios/TLS/cert, HTTP+cabeceras, rutas, WAF/cloud, mantenimiento, KUMO/Prism/CO N2). Presentación: filas `fc-row` prefijo "Semi-activo ·".	+ filas takeover, FinalRecon, API discovery, filas Strix por hallazgo	+ filas banner/CVE/pivot, Strix deep
GC (cibest)	Mismo set pasivo de la fila TPRA. Presentación: Pasivo · grupo tras el bloque externo (WHOIS/DNSDumpster/Shodan).	Mismo set semi-activo de la fila TPRA. Presentación: Semi-activo · grupo + Strix AI Pentest.	+ takeover, API endpoints, port-scan, Strix *standard*	+ banners/CVE/pivot, Strix deep
BC (bancolombia)	Mismo set pasivo de la fila TPRA. Presentación: Pasivo · grupo tras el bloque externo.	Mismo set semi-activo de la fila TPRA. Presentación: Semi-activo · grupo + Strix AI Pentest.	+ takeover, API, port-scan, Strix *standard*	+ banners/CVE/pivot, Strix deep
S3 (scor3bank)	Mismo set pasivo de la fila TPRA. Presentación: spans `_pasivo_canon_span` + scorecard KPIs (HSTS/CSP/SPF/DMARC/DNSSEC/TLS).	Mismo set semi-activo de la fila TPRA. Presentación: spans `_semi_canon_span` + Strix span resumen.	+ spans port-scan/API, Strix top-3 hallazgos	+ spans banners/CVE/pivot, Strix deep
B1 (beta1)	Mismo set pasivo de la fila TPRA. Presentación: hallazgo resumen "Panorama pasivo canonico" (evidencia con todos los items).	Mismo set semi-activo de la fila TPRA. Presentación: hallazgo resumen "Panorama semi-activo canonico" + Strix resumen.	+ hallazgos takeover/API/vulns OSV, Strix por severidad	+ hallazgos banner/CVE/pivot, Strix críticos

Informe	Pasivo (N1) — mismo set en los 8	Semi-activo (N2) — mismo set en los 8, adicional al pasivo	Activo (N3)	Invasivo (N4)
B2 (b2_scorecard)	Mismo set pasivo de la fila TPRA. Presentación: hallazgo resumen.	Mismo set semi-activo de la fila TPRA. Presentación: hallazgo resumen + Strix (factor Pentest IA).	+ hallazgos takeover/API/port-scan, Strix	+ hallazgos banner/CVE/pivot, Strix críticos
B3 (b3_unified)	Mismo set pasivo de la fila TPRA. Presentación: hallazgo resumen + contexto OWASP.	Mismo set semi-activo de la fila TPRA. Presentación: hallazgo resumen + Strix.	+ hallazgos takeover/API/port-scan, Strix	+ hallazgos banner/CVE/pivot, Strix críticos

2. Qué hace Strix exactamente

Strix (usestrix/strix) es un agente IA de pentesting autónomo (Apache-2.0). Lanza agentes con LLM que actúan como un pentester real contra el objetivo.

2.1 Reconocimiento

Mapea la superficie de ataque: subdominios, fingerprinting, enumeración de endpoints y planificación del ataque.

2.2 Explotación real (no falsos positivos)

Inyecta SQL/NoSQL/cliente, SSRF, XSS, IDOR, auth bypass, deserialización, RCE, race conditions, JWT, API, cloud... **Cada hallazgo se valida con un PoC funcional** antes de reportarse.

2.3 Herramientas dentro de un sandbox Docker (Kali)

- Browser automatizado (Playwright) para XSS/clickjacking.
- Proxy de intercepción (Caido) para request/replay manipulation.
- Shell y command execution para explotación y post-explotación.
- Runtime Python para escribir y validar exploits (PoCs).
- Nuclei, ffuf y más preinstalados.
- Análisis estático (SAST) + dinámico (DAST).

2.4 Orquestación

Varios agentes en paralelo que colaboran y comparten hallazgos entre sí.

2.5 Salida accionable

Cada hallazgo con: severidad, CVSS, CWE/CVE, endpoint, pasos de remediación y el PoC. Emite JSON/SARIF + informe ejecutivo (resumen, metodología, recomendaciones).

2.6 Integración en este pipeline (por nivel, tolerante)

- **N1 pasivo**: no corre (no aplica por diseño) -> skipped.

- **N2 semi-activo**: strix -n --target https://dominio --scan-mode quick.
- **N3 activo**: --scan-mode standard.
- **N4 invasivo**: --scan-mode deep.
- Si falta binario strix / Docker / STRIX_LLM + LLM_API_KEY -> skipped sin romper el escaneo.
- Costo LLM controlable con --max-budget; parsea strix_runs/vulnerabilities.json y run.json.

3. Veredicto de validación del Índice Comparativo (Indice_Comparativo_Informes.xlsx)

Cruce del xlsx (4 hojas x 8 informes) contra el código real de los generadores y los sets canónicos pasivo_canon.py / semi_canon.py.

3.1 Validación cuantitativa - OK

Los **totales por columna cuadran** en las 4 hojas (conteo de celdas SI = nº declarado en la fila TOTAL).

3.2 Correcciones aplicadas en la versión corregida (..._corregido.xlsx)

- **Faltaban dimensiones** que el código sí genera y no tenían fila propia. Añadidas (SI en N2/N3/N4, vacías en N1 porque no hay dato en pasivo):
  - `WAF / CDN detectado` - item canónico N2 (semi_canon.py) en los 8 informes.
  - `Cloud storage / buckets públicos` - item canónico N2.
  - `KUMO N2 - Favicon hash` - item canónico N2.
  - `Prism N2 - Website Analyzer` - item canónico N2.
  - `Claude-OSINT N2 - Secret scan` - item canónico N2.
  - `Strix AI Pentest (validación con PoC)` - en los 8 informes, solo si status==ok (bloque strix_block TPRA/GC/BC, filas fc-row PP, span S3, hallazgo "Pentest IA" B2/B3).
- **Pasivo (N1) - SI retirados por cobertura inexistente** (gates test_level en _scan_provider):
  - "Puertos abiertos (80/443)" B/C/I -> vacío (puertos solo desde N2).
  - "OSINT semi-activo (probes OIDC/SAML/ADFS)" C/F/I -> vacío (probes N2+).
  - "Factor OSINT semi-activo en puntaje" G/I -> vacío.
- **Semi-activo - "Score" D/E = SI**: GC y BC muestran grade-hero /100 en todos los niveles (el documento los dejaba vacíos).
- **"Resultado (score numéricamente distinto...)" movido fuera de la matriz**: es nota metodológica; queda como NOTA debajo de la fila TOTAL y deja de contar.

3.3 Observaciones por confirmar (no corregidas)

Semi-activo "Score general": tras el fix queda SI en las 8 columnas (coherente). "Superficie de ataque" + "Superficie ampliada" solapan parcialmente con las filas granulares; se mantienen por criterio del autor.